

MONEY CARD

M0 — SHARED SYSTEM CONTRACT

FINAL HANDOVER — FROZEN V1 • UPDATED V10 • COMPLETE DEVELOPER 2 API CONTRACT

Source baseline: uploaded M0 Updated V9. This V10 incorporates the latest approved product/UI/backend decisions.

IMPORTANT: This document supersedes the uploaded V9 wherever this V10 explicitly changes a rule. Developer 2 must implement this document as the backend/database contract. If an existing codebase conflicts with V10, stop and report the conflict instead of silently preserving the old behavior.

0. Contract Rules & Responsibilities

- M0 is the single source of truth for V1 business rules, roles, permissions, database schema, API behavior, validation, security, state machines, mock behavior, and acceptance criteria.
- Developer 1: React Web for Super Admin and Organization Admin, Web User Portal, and Flutter Staff application. All clients consume the same /api/v1 backend contract.
- Developer 2: shared Node.js/Express backend, PostgreSQL database, Prisma migrations, authentication, authorization, business logic, CSV processing, QR resolution, analytics, reports, subscriptions, plan overrides, audit logging, and deployment configuration.
- Do not silently change endpoint meaning, permission codes, status values, request/response shapes, or DB relationships.
- Any contract change requires an M0 update and review before implementation.
- One operational Staff role only. CASHIER and MANAGER are not separate roles.
- Staff authorization is always permission + assigned branch + same organization.
- User Portal authentication is separate from Staff/Admin authentication.
- Backend is authoritative for balances, prices, ownership, permissions, plan limits, subscriptions, transaction state, and branch scope.

0.1 Client Assignment

Client	Role	Purpose
React Web	SUPER_ADMIN	Platform administration
React Web	ORG_ADMIN	Organization administration
Flutter	STAFF	Operational cafeteria workflows
Web User Portal	USER	Current Card Session viewing
Shared API	All	/api/v1; no separate Flutter API

1. Roles, Scope & Permission Model

Role	Scope	Core responsibility
SUPER_ADMIN	Platform	Organizations, plans, organization plan assignment, organization-specific limit overrides, subscriptions, payment oversight, platform analytics, reports
ORG_ADMIN	One organization + all its branches	Organization, branches, staff, cards, products, inventory, analytics, reports, subscription view,

		contact Super Admin for plan changes
STAFF	Assigned branches only	Operational card/session/recharge/purchase/refund/inventory workflows according to permissions
USER	Current active Card Session	Balance, transactions, receipts, session/settlement information only

1.1 Permission Codes — Frozen

Area	Permission codes
Cards	CARD_VIEW, CARD_ISSUE, CARD_RETURN, CARD_BLOCK, CARD_UNBLOCK
Sessions / Payments	RECHARGE, PURCHASE, REFUND, SESSION_VIEW
Products / Inventory	PRODUCT_VIEW, PRODUCT_MANAGE, INVENTORY_VIEW, INVENTORY_MANAGE, INVENTORY_IMPORT
Analytics / Reports	VIEW_ANALYTICS, VIEW_REPORTS
Staff	STAFF_VIEW, STAFF_MANAGE
Branch	BRANCH_VIEW, BRANCH_MANAGE

2. Updated Business Rules

- Organization is a tenant. All operational data is isolated by organization.
- Branch is the operational cafeteria/kitchen/location concept. Do not create a separate Kitchen entity.
- A QR Card is reusable and does not represent a permanent wallet or permanent user ownership.
- A Card Session is the temporary wallet attached to one card and one branch.
- A card may have many historical sessions but only one ACTIVE session.
- Blocked cards cannot be used. Blocking does not automatically refund or close an active session.
- Organization Admin can monitor sessions but operational session actions remain Staff workflows.
- Monthly transaction counts may be displayed for analytics/reporting. THERE IS NO TRANSACTION LIMIT OR TRANSACTION QUOTA.
- No plan field named transaction_limit, monthly_transaction_limit, transaction_quota, or equivalent may be enforced.
- Organization-specific plan overrides can change staff, branch, and card limits for one organization without modifying the global Plan.
- Org Admin cannot directly upgrade/downgrade/change a plan through a payment gateway. Org Admin uses a Contact Super Admin / plan-change request flow.
- Super Admin can assign a plan to an organization and customize that organization's staff/branch/card limits.
- There is no Organization Admin subscription checkout gateway in V1.
- Card Session recharge uses CASH and manually verified UPI only; no automatic recharge gateway/webhook.
- Analytics preview and analytics PDF export share the exact same authorization and scope.
- Reports are PDF download only.
- Product Tags are removed. Product category/attributes are multi-select.
- CSV import is branch-scoped. Selected branch context is sent to backend; branch ownership is server-validated.
- CSV import must never partially commit.

3. Database Schema — Final V10

IMPORTANT: The V9 schema contained Plan.transaction_limit and Product.tags. Both are removed in V10.

Organization

id • name • status • created_at • updated_at

Plan

id • name • status • price • currency • billing_interval • branch_limit • staff_limit • card_limit • inventory_level • reports_level • analytics_level • multi_branch_enabled • white_label_enabled • support_level • created_at • updated_at

OrganizationSubscription

id • organization_id • plan_id • status • start_date • end_date • renewal_date • payment_status • created_at • updated_at

OrganizationSubscriptionLimitOverride

id • subscription_id • staff_limit_override nullable • branch_limit_override nullable • card_limit_override nullable • created_at • updated_at

PlanChangeRequest

id • organization_id • requested_by_user_id • current_plan_id • requested_plan_id • request_type • message • status • admin_note nullable • created_at • updated_at • resolved_at nullable

Branch

id • organization_id • name • status • created_at • updated_at

Staff

id • organization_id • name • email • password_hash/auth_identifier • status • created_at • updated_at

Permission

id • code • name

StaffPermission

staff_id • permission_id • unique pair

StaffBranch

staff_id • branch_id • unique pair

Card

id • qr_token/hash_reference • physical_card_number • status • current_branch_id • created_at • updated_at

CardSession

id • card_id • branch_id • status • balance • started_at • settled_at • created_at • updated_at

Product

id • branch_id • item_name • category[] • price • status • created_at • updated_at

Inventory

id • branch_id • product_id • quantity • updated_at

Transaction

id • session_id • branch_id • type • amount • status • created_at

Payment

id • transaction_id • amount • status • payment_method • external_reference nullable • created_at

AuditLog

id • organization_id nullable • branch_id nullable • actor_user_id nullable • action • resource_type • resource_id • metadata • created_at

3.1 Product Category Storage

- V1 product category/attribute selection is multi-select.
- Use PostgreSQL text array (for example Prisma String[]) or an equivalent normalized structure that preserves the same API contract: category is returned as an array of strings.
- Do not create a separate Tags field.
- Suggested values are selectable only and are not mandatory.

Category group	Suggested values
Food Type	Veg, Non-Veg, Vegan, Vegetarian, Egg, Contains Dairy
Meal Type	Breakfast, Lunch, Dinner, Snack, Beverage, Dessert
Food Category	Main Course, Starter, Rice, Curry, Bread, Salad, Soup, Sandwich, Fast Food, Bakery
Dietary / Product Attributes	Spicy, Mild, Sweet, Sugar-Free, Gluten-Free, High Protein

4. Relationships, Constraints & Indexes

- Organization 1:N Branch.
- Organization 1:N Staff.
- Staff M:N Branch through StaffBranch.
- Staff M:N Permission through StaffPermission.
- Branch 1:N Product, Inventory, CardSession; cards are assigned to a current branch.
- Card 1:N historical CardSession; max one ACTIVE CardSession.
- CardSession 1:N Transaction.
- Transaction 1:0..1 Payment for Card Session recharge/payment records as applicable.
- Organization 1:N OrganizationSubscription history; one current active subscription.
- OrganizationSubscription 1:1 optional OrganizationSubscriptionLimitOverride.
- Organization 1:N PlanChangeRequest.
- AuditLog belongs optionally to organization/branch and records actor/resource.
- Use PostgreSQL NUMERIC(12,2) for money.
- Primary keys unique; foreign keys enforce ownership relationships.
- Permission.code unique.
- Staff email unique according to account scope.
- StaffPermission unique(staff_id, permission_id).
- StaffBranch unique(staff_id, branch_id).
- Card QR token unique; physical card number unique within approved scope.
- Index organization_id, branch_id, card_id, session_id, product_id, staff_id, subscription_id, status, created_at where appropriate.
- Prevent more than one ACTIVE CardSession per card using a partial unique index and transaction-safe logic.
- Prevent orphaned branch/organization records.

5. State Machines

Entity	State flow
Card	AVAILABLE → ACTIVE → AVAILABLE after return/settlement; ACTIVE ↔ BLOCKED according to block rules
CardSession	ACTIVE → SETTLED/CLOSED after return/settlement
Transaction	PENDING → SUCCESS or FAILED; eligible successful transactions → REFUNDED
PlanChangeRequest	PENDING → APPROVED / REJECTED / CANCELLED
Subscription	PENDING_ACTIVATION → ACTIVE → RENEWAL_DUE → ACTIVE, or EXPIRED; history preserved

6. API Conventions

- Base path: /api/v1.
- JSON for normal requests/responses; multipart/form-data for CSV uploads.
- Success envelope: { success: true, data: {...} }.
- Error envelope: { success: false, error: { code, message } }.
- Authenticated endpoints use Bearer access token or agreed server authentication mechanism; refresh token handling is defined below.
- Server determines organization and branch scope from authenticated identity and resource ownership.
- Do not trust client-supplied organizationId, permission, price, balance, or ownership.
- List endpoints use page, limit, search, sortBy, sortOrder, status, branchId where applicable.
- Sorting/filter fields must be whitelisted.
- Recommended list response: {success:true,data:{items:[],pagination:{page,limit,total,totalPages}}}.

7. COMPLETE API ENDPOINT INVENTORY — V10

IMPORTANT: This is the authoritative endpoint list for Developer 2. The endpoint names below are frozen unless M0 is updated.

Authentication

Field	Contract
Method	POST
Endpoint	/api/v1/auth/login
Purpose	Authenticate Super Admin, Org Admin, or Staff.
Authentication	Public
Permission	None
Scope	Identity determined by account
Query	—
Request Body	{"email":"staff@example.com","password":"password"}
Success	200
Success Response	{"user":{"...},"accessToken":"..."}
Errors	400, 401
DB / Side Effects	Create/rotate refresh session as configured; audit login.
Idempotency	Do not duplicate active session unexpectedly

Field	Contract
Method	POST
Endpoint	/api/v1/auth/refresh
Purpose	Rotate refresh session and issue a new access token.
Authentication	Refresh credential
Permission	None
Scope	Authenticated refresh session
Query	—
Request Body	Refresh cookie/token

Success	200
Success Response	{"accessToken":"..."}
Errors	401
DB / Side Effects	Rotate refresh token; invalidate previous token/session.
Idempotency	Idempotent-safe rotation

Field	Contract
Method	POST
Endpoint	/api/v1/auth/logout
Purpose	Revoke refresh session.
Authentication	Access + refresh context
Permission	None
Scope	Current identity
Query	—
Request Body	—
Success	200
Success Response	{"loggedOut":true}
Errors	401
DB / Side Effects	Revoke refresh session.
Idempotency	Repeated logout safe

Field	Contract
Method	GET
Endpoint	/api/v1/auth/me
Purpose	Return current identity, organization, permissions, assigned branches.
Authentication	Access token
Permission	None
Scope	Current identity
Query	—
Request Body	—
Success	200
Success Response	{"user":{"..."},"organization":{"..."},"permissions":[],"branches":[]}
Errors	401
DB / Side Effects	None
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/auth/forgot-password
Purpose	Start password reset without revealing account existence.
Authentication	Public
Permission	None
Scope	Account lookup
Query	—
Request Body	{"email":"user@example.com"}
Success	200
Success Response	{"message":"If the account exists, reset instructions were sent."}
Errors	400
DB / Side Effects	Create one-time time-limited reset token.
Idempotency	Repeated requests must not reveal existence

Field	Contract
Method	POST
Endpoint	/api/v1/auth/reset-password
Purpose	Consume reset token and set new password.
Authentication	Reset token
Permission	None
Scope	Token-scoped
Query	—
Request Body	{"token":"...", "newPassword":"..."}
Success	200
Success Response	{"reset":true}
Errors	400, 401
DB / Side Effects	Invalidate reset token; update password hash.

Idempotency	Token one-time
-------------	----------------

Field	Contract
Method	POST
Endpoint	/api/v1/auth/change-password
Purpose	Change authenticated password.
Authentication	Access token
Permission	None
Scope	Current identity
Query	—
Request Body	{"currentPassword":"...", "newPassword":"..."}
Success	200
Success Response	{"changed":true}
Errors	400,401
DB / Side Effects	Update password hash; optionally revoke sessions.
Idempotency	Repeated call requires current credentials

Super Admin — Organizations

Field	Contract
Method	GET
Endpoint	/api/v1/admin/organizations
Purpose	List organizations.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	page,limit,search,status,sortBy,sortOrder
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/admin/organizations
Purpose	Create organization.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	{"name":"Acme Cafeteria"}
Success	201
Success Response	organization
Errors	400,403
DB / Side Effects	Create organization and optional initial subscription/plan assignment if explicitly requested.
Idempotency	Do not duplicate

Field	Contract
Method	GET
Endpoint	/api/v1/admin/organizations/:id
Purpose	Get organization details.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	—
Success	200
Success Response	organization + effective limits + subscription
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/admin/organizations/:id
Purpose	Update organization details/status.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	{"name":"...", "status":"ACTIVE"}
Success	200
Success Response	organization
Errors	400,403,404
DB / Side Effects	Update organization/audit.
Idempotency	Safe update

Super Admin — Plans

Field	Contract
Method	GET
Endpoint	/api/v1/admin/plans
Purpose	List plans.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	status,page,limit
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/admin/plans
Purpose	Create plan.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	{"name":"Pro", "price":0, "currency":"INR", "billingInterval":"MONTHLY", "branchLimit":10, "staffLimit":75, "cardLimit":5000,...}
Success	201
Success Response	plan
Errors	400,403
DB / Side Effects	Create plan; no transaction-limit field.
Idempotency	Do not duplicate

Field	Contract
Method	GET
Endpoint	/api/v1/admin/plans/:id
Purpose	Get plan.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	—
Success	200
Success Response	plan
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/admin/plans/:id
Purpose	Update global plan configuration.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	partial plan fields excluding transaction limit
Success	200
Success Response	plan
Errors	400,403,404
DB / Side Effects	Update global defaults; does not modify organization overrides.
Idempotency	Safe update

Super Admin — Organization Plan Assignment & Overrides

Field	Contract
Method	GET
Endpoint	/api/v1/admin/organizations/:id/subscription
Purpose	Get current subscription/effective limits.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Target organization
Query	—
Request Body	—
Success	200
Success Response	subscription + plan + effectiveLimits + overrides
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/admin/organizations/:id/subscription
Purpose	Assign/change organization's plan and status.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Target organization
Query	—
Request Body	{"planId":"PLAN_PRO","status":"ACTIVE","startDate":"...","renewalDate":"..."}
Success	200
Success Response	subscription + effectiveLimits
Errors	400,403,404
DB / Side Effects	Update subscription; recalculate effective limits; audit.
Idempotency	Idempotent by current desired state

Field	Contract
Method	GET
Endpoint	/api/v1/admin/organizations/:id/limit-overrides
Purpose	Get organization-specific staff/branch/card overrides.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Target organization
Query	—
Request Body	—
Success	200
Success Response	overrides + effectiveLimits
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH

Endpoint	/api/v1/admin/organizations/:id/limit-overrides
Purpose	Set organization-specific staff/branch/card limits.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Target organization
Query	—
Request Body	{"staffLimit":40,"branchLimit":4,"cardLimit":2500}
Success	200
Success Response	overrides + effectiveLimits
Errors	400,403,404
DB / Side Effects	Upsert override; audit.
Idempotency	Idempotent upsert

Field	Contract
Method	GET
Endpoint	/api/v1/admin/subscriptions
Purpose	List organization subscriptions.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	page,limit,organizationId,planId,status
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/admin/subscriptions/:id
Purpose	Get subscription detail.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	—
Success	200
Success Response	subscription + payments + overrides
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/admin/subscription-payments
Purpose	List subscription payment/history records.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	page,limit,organizationId,status
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Super Admin — Plan Change Requests

Field	Contract
Method	GET
Endpoint	/api/v1/admin/plan-change-requests
Purpose	List requests from organizations.
Authentication	Access token

Permission	SUPER_ADMIN
Scope	Platform
Query	page,limit,status,organizationId,requestType
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/admin/plan-change-requests/:id
Purpose	Get request detail.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	—
Success	200
Success Response	request + organization + plan details
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/admin/plan-change-requests/:id
Purpose	Approve/reject/cancel a request.
Authentication	Access token
Permission	SUPER_ADMIN
Scope	Platform
Query	—
Request Body	{"status":"APPROVED","adminNote":"..."}
Success	200
Success Response	request
Errors	400,403,404
DB / Side Effects	If approved, apply plan/subscription change or mark ready for Super Admin confirmation; audit.
Idempotency	Idempotent state transition

Organization

Field	Contract
Method	GET
Endpoint	/api/v1/organization
Purpose	Get current organization profile/effective subscription information.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	organization + subscription + effectiveLimits
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/organization
Purpose	Update organization profile/settings.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—

Request Body	{"name":"..."}
Success	200
Success Response	organization
Errors	400,403
DB / Side Effects	Update organization/audit.
Idempotency	Safe update

Branches

Field	Contract
Method	GET
Endpoint	/api/v1/branches
Purpose	List accessible branches.
Authentication	Access token
Permission	ORG_ADMIN or BRANCH_VIEW
Scope	Own organization; Staff assigned branches
Query	page,limit,search,status,sortBy,sortOrder
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/branches
Purpose	Create branch.
Authentication	Access token
Permission	ORG_ADMIN or BRANCH_MANAGE
Scope	Own organization
Query	—
Request Body	{"name":"Main Cafeteria"}
Success	201
Success Response	branch
Errors	400,403
DB / Side Effects	Check effective branch limit; create branch; audit.
Idempotency	Do not exceed effective limit

Field	Contract
Method	GET
Endpoint	/api/v1/branches/:id
Purpose	Get branch.
Authentication	Access token
Permission	ORG_ADMIN or BRANCH_VIEW
Scope	Own org / assigned branch
Query	—
Request Body	—
Success	200
Success Response	branch
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/branches/:id
Purpose	Update branch.
Authentication	Access token
Permission	ORG_ADMIN or BRANCH_MANAGE
Scope	Own organization
Query	—
Request Body	{"name":"...", "status":"ACTIVE"}
Success	200
Success Response	branch

Errors	400,403,404
DB / Side Effects	Update/audit.
Idempotency	Safe update

Staff

Field	Contract
Method	GET
Endpoint	/api/v1/staff
Purpose	List staff.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_VIEW
Scope	Own organization; Staff sees permitted scope
Query	page,limit,search,status,branchId
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/staff
Purpose	Create staff.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_MANAGE
Scope	Own organization
Query	—
Request Body	{"name":"John","email":"john@example.com","permissions":["CARD_VIEW"],"branchIds":["branch_001"]}
Success	201
Success Response	staff summary
Errors	400,403,409
DB / Side Effects	Create staff, permissions, branch assignments; audit.
Idempotency	Email uniqueness

Field	Contract
Method	GET
Endpoint	/api/v1/staff/:id
Purpose	Get staff details.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_VIEW
Scope	Own organization
Query	—
Request Body	—
Success	200
Success Response	staff + permissions + branches
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/staff/:id
Purpose	Edit staff basic details/status.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_MANAGE
Scope	Own organization
Query	—
Request Body	{"name":"...", "status":"ACTIVE"}
Success	200
Success Response	staff
Errors	400,403,404
DB / Side Effects	Update/audit.

Idempotency	Safe update
-------------	-------------

Field	Contract
Method	PUT
Endpoint	/api/v1/staff/:id/branches
Purpose	Replace branch assignments.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_MANAGE
Scope	Own organization
Query	—
Request Body	{"branchIds":["branch_001","branch_002"]}
Success	200
Success Response	assignments
Errors	400,403,404
DB / Side Effects	Replace StaffBranch rows after ownership validation; audit.
Idempotency	Idempotent replacement

Field	Contract
Method	PUT
Endpoint	/api/v1/staff/:id/permissions
Purpose	Replace permissions.
Authentication	Access token
Permission	ORG_ADMIN or STAFF_MANAGE
Scope	Own organization
Query	—
Request Body	{"permissions":["CARD_VIEW","PURCHASE"]}
Success	200
Success Response	permissions
Errors	400,403,404
DB / Side Effects	Replace StaffPermission rows; audit.
Idempotency	Idempotent replacement

Permissions

Field	Contract
Method	GET
Endpoint	/api/v1/permissions
Purpose	List frozen permission catalog.
Authentication	Access token
Permission	Authenticated Admin/Staff as allowed
Scope	Platform or current organization
Query	—
Request Body	—
Success	200
Success Response	permissions[]
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Cards

Field	Contract
Method	GET
Endpoint	/api/v1/cards
Purpose	List cards.
Authentication	Access token
Permission	CARD_VIEW or ORG_ADMIN
Scope	Own organization; branch filter enforced
Query	page,limit,search,status,branchId
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/cards
Purpose	Create/issue a card manually.
Authentication	Access token
Permission	CARD_ISSUE or ORG_ADMIN
Scope	Own org / selected branch
Query	—
Request Body	{"physicalCardNumber":"MC-001","branchId":"branch_001"}
Success	201
Success Response	card
Errors	400,403,409
DB / Side Effects	Create card; QR generated securely; enforce card limit.
Idempotency	Do not expose secret QR token unnecessarily

Field	Contract
Method	GET
Endpoint	/api/v1/cards/:id
Purpose	Get card details/audit summary.
Authentication	Access token
Permission	CARD_VIEW or ORG_ADMIN
Scope	Own org / branch scope
Query	—
Request Body	—
Success	200
Success Response	card + lifetime audit summary
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/cards/resolve
Purpose	Resolve card for Staff/User flow.
Authentication	Access token or public context depending on caller
Permission	CARD_VIEW for Staff; public for User resolution
Scope	Server-resolved card only
Query	—
Request Body	{"qrToken":"opaque-token"}
Success	200
Success Response	safe card resolution data
Errors	400,404,409
DB / Side Effects	Resolve card; must not grant privileges.
Idempotency	Read-only

Field	Contract
Method	POST
Endpoint	/api/v1/cards/:id/block
Purpose	Block card.
Authentication	Access token
Permission	CARD_BLOCK or ORG_ADMIN
Scope	Own org / branch
Query	—
Request Body	{"reason":"..."}
Success	200
Success Response	card
Errors	400,403,404,409
DB / Side Effects	Set BLOCKED; do not auto-refund/settle.
Idempotency	Repeated block safe

Field	Contract
Method	POST

Endpoint	/api/v1/cards/:id/unblock
Purpose	Unblock card.
Authentication	Access token
Permission	CARD_UNBLOCK or ORG_ADMIN
Scope	Own org / branch
Query	—
Request Body	—
Success	200
Success Response	card
Errors	400,403,404,409
DB / Side Effects	Set AVAILABLE if eligible.
Idempotency	Repeated unblock safe

Field	Contract
Method	POST
Endpoint	/api/v1/cards/import
Purpose	Bulk import cards.
Authentication	Access token
Permission	ORG_ADMIN or CARD_ISSUE
Scope	Selected/validated organization branch
Query	—
Request Body	multipart/form-data: file + branchId
Success	200
Success Response	import result + created/failed counts
Errors	400,403,409
DB / Side Effects	Validate all rows before transaction; create cards; AVAILABLE cards become issuable.
Idempotency	Idempotency key recommended

Field	Contract
Method	GET
Endpoint	/api/v1/cards/import/template
Purpose	Download card import template.
Authentication	Access token
Permission	ORG_ADMIN or CARD_ISSUE
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	CSV file
Errors	401,403
DB / Side Effects	No DB write
Idempotency	N/A

Card Sessions

Field	Contract
Method	POST
Endpoint	/api/v1/card-sessions
Purpose	Create ACTIVE session for AVAILABLE card.
Authentication	Access token
Permission	CARD_ISSUE
Scope	Own org + assigned branch
Query	—
Request Body	{"cardId":"CARD001","branchId":"BRANCH001"}
Success	201
Success Response	session
Errors	400,403,404,409
DB / Side Effects	Card AVAILABLE→ACTIVE; create session at balance 0.
Idempotency	Idempotency key recommended

Field	Contract
Method	GET
Endpoint	/api/v1/card-sessions
Purpose	List sessions for monitoring.
Authentication	Access token

Permission	ORG_ADMIN or SESSION_VIEW
Scope	Own org; branch filter/Staff assignments
Query	page,limit,search,status,cardStatus,sessionStatus,branchId,dateFrom,dateTo
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/card-sessions/:id
Purpose	Get session detail.
Authentication	Access token
Permission	ORG_ADMIN or SESSION_VIEW
Scope	Own org / branch scope
Query	—
Request Body	—
Success	200
Success Response	session + permitted transactions/payments
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/card-sessions/:id/recharge
Purpose	Recharge active session.
Authentication	Access token
Permission	RECHARGE
Scope	Own org + assigned branch
Query	—
Request Body	{"amount":500,"paymentMethod":"CASH UPI","externalReference":"optional"}
Success	200
Success Response	payment + updated balance
Errors	400,403,404,409,422
DB / Side Effects	Create Payment/Transaction and credit balance atomically.
Idempotency	Idempotency key required

Field	Contract
Method	POST
Endpoint	/api/v1/card-sessions/:id/purchase
Purpose	Purchase products from active session.
Authentication	Access token
Permission	PURCHASE
Scope	Own org + assigned branch
Query	—
Request Body	{"items":[{"productId":"PRODUCT001","quantity":1}]}
Success	200
Success Response	transaction + updated balance + inventory result
Errors	400,403,404,409,422
DB / Side Effects	Authoritative price; deduct balance/inventory atomically.
Idempotency	Idempotency key required

Field	Contract
Method	POST
Endpoint	/api/v1/card-sessions/:id/return
Purpose	Return/settle session.
Authentication	Access token
Permission	CARD_RETURN
Scope	Own org + assigned branch
Query	—
Request Body	{}

Success	200
Success Response	settlement + refunded amount + card/session status
Errors	400,403,404,409
DB / Side Effects	Refund eligible remaining balance; settle session; balance 0; card AVAILABLE.
Idempotency	Idempotency key required

Field	Contract
Method	POST
Endpoint	/api/v1/card-sessions/:id/refund
Purpose	Explicit refund/settlement endpoint if retained by UI.
Authentication	Access token
Permission	REFUND
Scope	Own org + assigned branch
Query	—
Request Body	{}
Success	200
Success Response	refund + settlement
Errors	400,403,404,409
DB / Side Effects	Same settlement/refund safety rules; cannot double refund.
Idempotency	Idempotency key required

Products

Field	Contract
Method	GET
Endpoint	/api/v1/products
Purpose	List products.
Authentication	Access token
Permission	PRODUCT_VIEW or ORG_ADMIN
Scope	Own org; branch scope
Query	page,limit,search,status,branchId,category
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/products
Purpose	Create product.
Authentication	Access token
Permission	PRODUCT_MANAGE or ORG_ADMIN
Scope	Own org / selected branch
Query	—
Request Body	{"branchId":"branch_001","itemName":"Veg Burger","category":["Veg","Fast Food"],"price":120,"status":"ACTIVE"}
Success	201
Success Response	product
Errors	400,403,409
DB / Side Effects	Create product and audit; category array allowed.
Idempotency	Do not create tags

Field	Contract
Method	GET
Endpoint	/api/v1/products/:id
Purpose	Get product.
Authentication	Access token
Permission	PRODUCT_VIEW or ORG_ADMIN
Scope	Own org / branch
Query	—
Request Body	—
Success	200
Success Response	product

Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/products/:id
Purpose	Edit product.
Authentication	Access token
Permission	PRODUCT_MANAGE or ORG_ADMIN
Scope	Own org / branch
Query	—
Request Body	partial product; category remains array
Success	200
Success Response	product
Errors	400,403,404
DB / Side Effects	Update/audit.
Idempotency	Safe update

Inventory

Field	Contract
Method	GET
Endpoint	/api/v1/inventory
Purpose	List inventory.
Authentication	Access token
Permission	INVENTORY_VIEW or ORG_ADMIN
Scope	Own org / branch
Query	page,limit,search,status,branchId,productId
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	PATCH
Endpoint	/api/v1/inventory/:id
Purpose	Adjust stock.
Authentication	Access token
Permission	INVENTORY_MANAGE or ORG_ADMIN
Scope	Own org + branch
Query	—
Request Body	{"quantity":100,"reason":"Stock adjustment"}
Success	200
Success Response	inventory + movement result
Errors	400,403,404,409
DB / Side Effects	Atomic adjustment; no negative inventory; audit.
Idempotency	Idempotency key recommended

Field	Contract
Method	POST
Endpoint	/api/v1/inventory/import
Purpose	Import inventory/product CSV.
Authentication	Access token
Permission	INVENTORY_IMPORT or ORG_ADMIN
Scope	Selected branch context + org ownership
Query	—
Request Body	multipart/form-data: file + branchId
Success	200
Success Response	preview/import result
Errors	400,403,409,422
DB / Side Effects	Validate entire file, preview, then transaction; no partial commit.
Idempotency	Idempotency key required on confirm

Field	Contract
Method	GET
Endpoint	/api/v1/inventory/import/template
Purpose	Download inventory/product CSV template.
Authentication	Access token
Permission	INVENTORY_IMPORT or ORG_ADMIN
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	CSV file
Errors	401,403
DB / Side Effects	No DB write
Idempotency	N/A

Analytics

Field	Contract
Method	GET
Endpoint	/api/v1/analytics
Purpose	Analytics preview.
Authentication	Access token
Permission	VIEW_ANALYTICS or authorized ORG_ADMIN/SUPER_ADMIN
Scope	SUPER_ADMIN=platform; ORG_ADMIN=org; Staff=assigned branch
Query	dateFrom,dateTo,branchId,metric,groupBy,filters
Request Body	—
Success	200
Success Response	analytics dataset + metadata
Errors	401,403,422
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/analytics/export
Purpose	Export exact analytics dataset as PDF.
Authentication	Access token
Permission	VIEW_ANALYTICS or authorized ORG_ADMIN/SUPER_ADMIN
Scope	EXACT same scope as preview
Query	dateFrom,dateTo,branchId,metric,groupBy,filters,format=pdf
Request Body	—
Success	200
Success Response	application/pdf
Errors	401,403,422
DB / Side Effects	Generate PDF from same authorization/query scope.
Idempotency	Read-only

Reports

Field	Contract
Method	GET
Endpoint	/api/v1/reports
Purpose	List/formalize available reports or generate requested report.
Authentication	Access token
Permission	VIEW_REPORTS or authorized ORG_ADMIN/SUPER_ADMIN
Scope	Same organization/platform rules
Query	type,dateFrom,dateTo,branchId,page,limit
Request Body	—
Success	200
Success Response	report metadata or report payload
Errors	401,403,422
DB / Side Effects	Read only/report generation; no CSV/Excel/JSON download.
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/reports/:id/pdf
Purpose	Download a formal report as PDF.
Authentication	Access token
Permission	VIEW_REPORTS or authorized ORG_ADMIN/SUPER_ADMIN
Scope	Same organization/platform scope
Query	—
Request Body	—
Success	200
Success Response	application/pdf
Errors	401,403,404
DB / Side Effects	Read/generate report; audit if required.
Idempotency	N/A

Organization Subscription / Contact Super Admin

Field	Contract
Method	GET
Endpoint	/api/v1/plans
Purpose	List plans visible to Org Admin for comparison.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	status
Request Body	—
Success	200
Success Response	plans[]
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/subscription
Purpose	Get current subscription/effective limits/usage.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	subscription + plan + effectiveLimits + usage
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/subscription/payments
Purpose	Get organization subscription/payment history.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	page,limit,status
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET

Endpoint	/api/v1/subscription/payments/:id
Purpose	Get one subscription payment record.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	payment record
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	POST
Endpoint	/api/v1/plan-change-requests
Purpose	Create Contact Super Admin plan-change request.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—
Request Body	{"requestedPlanId":"PLAN_PRO","requestType":"UPGRADE DOWNGRADE ENTERPRISE","message":"..."}
Success	201
Success Response	request
Errors	400,403,409
DB / Side Effects	Create PENDING request; notify via dashboard/in-app request list if implemented.
Idempotency	Do not activate plan

Field	Contract
Method	GET
Endpoint	/api/v1/plan-change-requests
Purpose	List own plan-change requests.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	page,limit,status
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,403
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/plan-change-requests/:id
Purpose	Get own request.
Authentication	Access token
Permission	ORG_ADMIN
Scope	Current organization
Query	—
Request Body	—
Success	200
Success Response	request
Errors	403,404
DB / Side Effects	Read only
Idempotency	N/A

Public User Portal

Field	Contract
Method	POST
Endpoint	/api/v1/public/cards/resolve

Purpose	Resolve public QR card token.
Authentication	Public
Permission	None
Scope	Card token only
Query	—
Request Body	{"qrToken":"opaque-card-token"}
Success	200
Success Response	safe card/session eligibility data
Errors	400,404,409
DB / Side Effects	May establish/prepare User Portal session context; never Staff/Admin auth.
Idempotency	Do not expose raw token

Field	Contract
Method	POST
Endpoint	/api/v1/public/sessions/access
Purpose	Create separate User Portal session token for eligible active Card Session.
Authentication	Public card context
Permission	None
Scope	Current active card session only
Query	—
Request Body	{"cardToken":"opaque-card-token"}
Success	200
Success Response	{"sessionToken":"...", "expiresAt":"..."}
Errors	400,404,409
DB / Side Effects	Create/revokeable portal session token.
Idempotency	Repeated access should not create unlimited uncontrolled tokens

Field	Contract
Method	GET
Endpoint	/api/v1/public/sessions/:sessionToken
Purpose	Get current session information.
Authentication	Portal session token
Permission	None
Scope	Token-scoped current session
Query	—
Request Body	—
Success	200
Success Response	sessionId, cardDisplayNumber, status, balance, branchDisplayName, startedAt, settledAt, settlement/refund status
Errors	401,404,410
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/public/sessions/:sessionToken/transactions
Purpose	Get current session transactions.
Authentication	Portal session token
Permission	None
Scope	Token-scoped current session
Query	page,limit,type,status
Request Body	—
Success	200
Success Response	items + pagination
Errors	401,404,410
DB / Side Effects	Read only
Idempotency	N/A

Field	Contract
Method	GET
Endpoint	/api/v1/public/sessions/:sessionToken/receipts
Purpose	Get current session receipts.
Authentication	Portal session token
Permission	None

Scope	Token-scoped current session
Query	page,limit
Request Body	—
Success	200
Success Response	receipt records
Errors	401,404,410
DB / Side Effects	Read only
Idempotency	N/A

8. Canonical Request / Response Examples

Login

POST /api/v1/auth/login

Request: {"email":"staff@example.com","password":"password"}

Success: {"success":true,"data":{"accessToken":"token-value","user":{"id":"staff_001","name":"John","type":"STAFF","permissions":["CARD_VIEW","CARD_ISSUE","RECHARGE","PURCHASE","REFUND"],"branches":[{"id":"branch_001","name":"Main Cafeteria"}]}}

Create Session

POST /api/v1/card-sessions

Request: {"cardId":"CARD001","branchId":"BRANCH001"}

Success:

{"success":true,"data":{"id":"SESSION001","cardId":"CARD001","branchId":"BRANCH001","balance":0,"status":"ACTIVE"}}

Recharge

POST /api/v1/card-sessions/:id/recharge

Request: {"amount":500,"paymentMethod":"CASH"}

Success:

{"success":true,"data":{"sessionId":"SESSION001","paymentId":"PAYMENT001","amount":500,"balance":500,"status":"ACTIVE"}}

Purchase

POST /api/v1/card-sessions/:id/purchase

Request: {"items":[{"productId":"PRODUCT001","quantity":1}]}

Success:

{"success":true,"data":{"transactionId":"TXN001","amount":120,"balance":380,"status":"SUCCESS"}}

Return

POST /api/v1/card-sessions/:id/return

Request: {}

Success:

{"success":true,"data":{"sessionId":"SESSION001","refundedAmount":380,"sessionStatus":"SETTLED","cardStatus":"AVAILABLE"}}

Create Product

POST /api/v1/products

Request: {"branchId":"branch_001","itemName":"Veg Burger","category":["Veg","Fast Food"],"price":120,"status":"ACTIVE"}


```
Success: {"success":true,"data":{"id":"PRODUCT001","itemName":"Veg
Burger","category":["Veg","Fast Food"],"price":120,"status":"ACTIVE"}}
```

Plan Change Request

```
POST /api/v1/plan-change-requests
```

```
Request: {"requestedPlanId":"PLAN_PRO","requestType":"UPGRADE","message":"Need higher
staff/card limits."}
```

```
Success:
```

```
{"success":true,"data":{"id":"PCR001","status":"PENDING","requestedPlanId":"PLAN_PRO"}}
```

9. Standard Errors

HTTP	Codes	Meaning
400	VALIDATION_ERROR, CSV_VALIDATION_ERROR	Invalid input, headers, values, state-independent validation
401	UNAUTHORIZED	Missing/invalid/expired authentication
403	FORBIDDEN, PERMISSION_DENIED, ORGANIZATION_ACCESS_DENIED, BRANCH_ACCESS_DENIED	Authenticated but not allowed
404	NOT_FOUND, CARD_NOT_FOUND, SESSION_NOT_FOUND, SUBSCRIPTION_NOT_FOUND	Resource does not exist or is intentionally hidden
409	CARD_NOT_AVAILABLE, ALREADY_SETTLED, REFUND_ALREADY_PROCESSED, DUPLICATE_REQUEST, PLAN_LIMIT_REACHED, DOWNGRADE_LIMIT_EXCEEDED	Conflict/state/idempotency
410	PORTAL_SESSION_EXPIRED	User Portal session token expired/closed
422	INSUFFICIENT_BALANCE, INSUFFICIENT_INVENTORY, PAYMENT_VERIFICATION_FAILED, INVALID_BUSINESS_STATE	Business-rule validation
500	INTERNAL_SERVER_ERROR	Unexpected server failure

```
{"success":false,"error":{"code":"BRANCH_ACCESS_DENIED","message":"You do not have access to
this branch."}}
```

10. Authentication & Security Requirements

- Password hashes only; never plaintext.
- Short-lived access JWT and longer-lived refresh token/session.
- Refresh tokens rotate; previous refresh token/session is invalidated.
- Web refresh token uses secure HttpOnly cookie; do not use localStorage for refresh tokens.
- Flutter stores refresh credentials in platform secure storage.
- Logout revokes refresh session.
- Password reset is one-time and time-limited and never reveals whether an account exists.
- Inactive Staff/Admin/Organization accounts cannot authenticate or refresh.
- HTTPS required in production.
- No social login, SSO, or MFA in V1 unless separately approved.
- QR token is opaque and cryptographically random; it is not an authentication privilege.
- User Portal session token is separate from QR token and Staff/Admin credentials.
- Never trust organizationId, branchId, permission, price, balance, card ownership, or user identity supplied by the client.

11. Payment Rules — Final V10

11.1 Card Session Recharge

- Only CASH and manually verified UPI.
- No payment gateway and no automatic UPI webhook for Card Session recharge.
- CASH: user pays Staff → Staff verifies → backend records Payment → session credited.
- UPI: user pays organization/branch UPI → Staff verifies → backend records Payment → session credited.
- Screenshot alone is not authoritative proof.
- Payment uses payment_method CASH|UPI and optional external_reference.
- Recharge, Payment creation, transaction record, and balance update are atomic.
- Duplicate recharge requests cannot credit twice.

11.2 Subscription Plan Changes

- V10 removes the Organization Admin payment-gateway checkout model.
- Org Admin cannot call /subscription/checkout, /upgrade, /downgrade, /renew, /cancel, or /webhook because those V9 endpoints are removed from V10.
- Org Admin creates a PlanChangeRequest.
- Super Admin reviews the request and directly assigns/changes the organization's subscription and effective limits.
- Any external/direct payment arrangement is outside the application transaction flow; Super Admin records status/history as required.
- Do not implement gateway webhook activation for organization plan changes in V1.
- Never store raw card numbers, CVV, or sensitive payment credentials.

12. CSV Import — Final V10

- CSV flow: Download Template → Upload → Validate → Preview → Confirm → Import.
- The selected branch in the UI is the branch context.
- Frontend sends branchId as multipart field/validated API context; CSV does not need organizationId/branchId columns.
- Backend verifies branch.organization_id == authenticated user's organization_id.
- Main Cafeteria is not special-cased; it is a normal Branch record. If Main Cafeteria import fails, inspect branch ID resolution/authorization instead of hard-coding a branch name.
- Required product/inventory CSV columns in V10: itemName, category, price. Tags is REMOVED.
- Category may contain multiple values according to the agreed CSV representation; document the exact delimiter in the template and parser, e.g. 'Veg|Fast Food'.
- Same branch + same itemName → UPDATE.
- New itemName in branch → CREATE.
- Duplicate branch + itemName row inside one CSV → REJECT.
- Invalid row → row number + reason.
- Preview required before commit.
- No partial commit.
- Only approved CSV file type and size/row limits.
- All-or-nothing DB transaction for final import.

13. Analytics & Reports — Final V10

- Analytics page itself is the view; no separate 'View Analytics' button.

- Analytics may show monthly transaction counts, but there is NO transaction limit.
- Branch Performance must support meaningful comparison details rather than a single unexplained score.
- Demand/Peak area contains peak hours, busiest periods, product demand, top products, branch/day/hour demand and related demand metrics.
- Analytics export is PDF only in V10.
- GET /api/v1/analytics/export?format=pdf uses exactly the same role, permission, organization, branch, date and filter scope as GET /api/v1/analytics.
- No ANALYTICS_DOWNLOAD permission.
- Reports are separate formal documents and PDF only.
- Reports must not expose cross-organization data.

14. Plan Entitlements — Final V10

Feature	Basic	Standard	Pro	Enterprise
Branches	1	3	10	Custom
Staff accounts	10	25	75	Custom
Active Cards	250	1,000	5,000	Custom
Transaction limit	NONE	NONE	NONE	NONE
Inventory	Basic	Advanced	Advanced	Advanced
CSV Import	Yes	Yes	Yes	Yes
Basic Reports	Yes	Yes	Yes	Yes
Analytics	Basic	Standard	Advanced	Advanced
Multi-branch	No	Yes	Yes	Yes
White-label	Yes	Yes	Yes	Yes
Support	Standard	Priority	Priority	Dedicated

IMPORTANT: There is no monthly transaction entitlement. Monthly transaction volume is an analytics/reporting metric only.

- Commercial prices are configurable Plan data.
- Enterprise limits are custom and may be applied by Super Admin through organization-specific overrides.
- Plan limit enforcement applies only to branch/staff/card limits that actually exist in V10.

15. Validation Rules

- Auth: required fields, valid credentials, active account/organization.
- Organization/Branch: resource must belong to authenticated organization; Staff must be assigned to target branch.
- Staff: unique email, valid permissions, same-organization branch assignments.
- Card: unique QR/card identifier; session only if AVAILABLE; BLOCKED cannot be used; max one active session.
- Recharge: amount > 0, active session, RECHARGE permission, correct branch, CASH/UPI only.
- Purchase: active session, PURCHASE permission, correct branch, active product, positive quantity, sufficient balance/inventory, server-calculated price.
- Refund/Return: active/eligible session, correct branch, required permission, cannot refund twice, remaining balance handled atomically.
- CSV: required headers, valid price, duplicate-row rejection, branch ownership, preview, all-or-nothing commit.
- Analytics: server-side role + permission + organization + branch scope.
- Plan override: only Super Admin; effective value must be valid and must not create an invalid organization state.

- Plan change request: valid target plan, current organization, no activation on request creation.

16. Audit Logging

- Audit login/security events.
- Audit organization creation/update/status.
- Audit branch creation/update/status.
- Audit staff creation, status, permissions and branch assignments.
- Audit card issue/import/block/unblock/return.
- Audit recharge, purchase, refund/settlement.
- Audit product/inventory changes and CSV imports.
- Audit plan creation/update, organization plan assignment, plan overrides, plan change requests and subscription changes.
- Audit important analytics/report access where policy requires.
- Audit records include actor, organization/branch scope, action, resource type, resource ID, timestamp and metadata.
- Normal application workflows cannot edit/delete audit records.

17. Developer 2 Local Setup & Environment

- PostgreSQL required for real backend testing.
- Prisma migrations are mandatory; do not manually alter production schema.
- Provide repeatable reset/migrate/seed commands.
- Provide .env.example only; never commit secrets.

Variable	Required purpose
DATABASE_URL	PostgreSQL connection
JWT_ACCESS_SECRET	Access token signing
JWT_REFRESH_SECRET	Refresh token signing
ACCESS_TOKEN_TTL	Short access-token expiry
REFRESH_TOKEN_TTL	Refresh session expiry
APP_BASE_URL	Web/API base URL
USER_PORTAL_BASE_URL	QR/User Portal URL base
QR_TOKEN_SECRET / generator config	Opaque QR token generation/verification if required
CSV_MAX_FILE_SIZE	Upload limit
CSV_MAX_ROWS	Import row limit

IMPORTANT: Payment gateway and subscription webhook environment variables from V9 are removed from V10 because V1 no longer uses Organization Admin gateway checkout for plan changes.

18. Mock API Requirements

- Mock API must mirror V10 endpoint paths, methods, request shapes, response envelopes and error codes.
- Mock state must simulate cards, sessions, balances, purchases, refunds, inventory, plan assignment, organization overrides and plan-change requests.
- Mock must include Main Cafeteria and another branch for branch-isolation testing.
- Mock must include an AVAILABLE card that appears in the Cards Available filter.
- Mock must include products with category arrays and no tags.
- Mock must include analytics monthly counts without transaction quotas.
- Mock must include PDF export behavior at contract level.
- Postman can test mock endpoints before the real backend is complete.

- When real backend is ready, frontend service implementation switches without rewriting page components.

19. Developer 2 Test Matrix

Test	Expected result
Login valid	200; access token + identity
Login invalid	401; no account existence leak
Refresh reuse	Old refresh token/session rejected after rotation
Disabled account	Login/refresh rejected
Staff unassigned branch	403 BRANCH_ACCESS_DENIED
Forged organization ID	403 / ownership rejection
Create session with BLOCKED card	409 CARD_NOT_AVAILABLE/CARD_BLOCKED
Second active session same card	409
Recharge same idempotency key twice	One financial effect
Concurrent purchase	No double spend
Insufficient balance	422; no inventory change
Insufficient inventory	422; no balance change
Refund twice	Second request rejected
CSV duplicate row	Rejected before commit
CSV invalid row	Preview reports row/reason; no partial commit
Main Cafeteria CSV	Imports into selected branch only
Same itemName same branch	UPDATE
Same itemName different branch	CREATE separate branch record
Product categories	Multiple values persist and return as array
Tags field	Not stored/required
Transaction limit	No quota enforced
Super Admin plan override	Only target organization changes
Other organization	Unaffected by override
Org Admin plan change	Creates request; does not activate plan
Super Admin approve/change	Subscription/effective limits update
Analytics export	PDF only; same scope as preview
Reports	PDF only
User Portal token	Cannot access another session
QR token	Cannot grant Admin/Staff privileges

20. Core End-to-End Workflows

Issue / Recharge

Staff login → permission + branch verification → scan QR → AVAILABLE card → create ACTIVE session → recharge → record payment → balance updated.

Purchase

Scan card → ACTIVE session → PURCHASE permission + branch → validate product/inventory/balance → purchase → deduct balance → deduct inventory.

Return / Refund

Staff scans → REFUND/CARD_RETURN + branch → calculate eligible balance → refund → settle session → balance 0 → card AVAILABLE.

Later reuse

Card remains ACTIVE while user is away → same active session continues → purchases continue → eventual return settles session.

CSV

Select branch → download template → upload → validate branch ownership → validate rows → preview → confirm → atomic import.

Org plan change

Org Admin opens subscription → selects requested plan → Contact Super Admin → create PlanChangeRequest → Super Admin reviews → approve/reject → Super Admin assigns plan/overrides → effective limits updated.

Analytics

Authorized user selects scope/filters → backend validates scope → analytics preview → PDF export uses identical scope.

User Portal

QR → resolve opaque card token → verify eligible active session → create separate portal token → session/balance/transactions/receipts.

21. V9 Items Explicitly Removed / Superseded

Removed from V9	V10 replacement
Plan.transaction_limit	Removed; no transaction quota.
Monthly transaction plan entitlements	Monthly transaction count is analytics/reporting only.
Product.tags	Removed; category is multi-select.
CSV required tags column	Removed.
Subscription checkout endpoint	Removed; Org Admin contacts Super Admin.
Subscription upgrade/downgrade endpoints	Removed from Org Admin flow; Super Admin changes subscription.
Subscription renew/cancel endpoints	Removed from V1 plan-change flow.
Subscription webhook endpoint	Removed from V1 application flow.
Organization Admin payment gateway checkout	Removed.
Analytics CSV export	Removed; Analytics export is PDF only.
Separate View Analytics button	Removed from UI; analytics page is the view.
Org Admin Current Plan Overview in Settings	Removed; subscription lives in subscription area.
Standalone '(1 available)' card label	Removed; Available count belongs inside card filters/counts.

IMPORTANT: These removals are intentional. Do not reintroduce them because they still exist in older code or documentation.

22. Final Acceptance / Definition of Done

- All V10 endpoints exist, are protected according to the authorization rules, and return the standard envelope.
- All database migrations match V10 schema; transaction_limit and Product.tags are absent.
- Organization-specific plan overrides work and affect only the selected organization.
- Org Admin plan change creates a request and does not directly activate a plan.
- Super Admin can approve/change subscription and override staff/branch/card limits for one organization.
- No transaction quota is enforced or displayed as an entitlement.
- Cards support CSV import and AVAILABLE cards can be selected for issuing.
- Main Cafeteria and all other branches use branch IDs and organization ownership checks.
- Products support multi-select category values and do not use tags.
- Sessions support Card Status and Session Status filtering.
- Analytics supports detailed branch comparison, demand/peak analytics, monthly counts, and PDF export.
- Analytics export uses identical authorization/filter scope as preview.
- Reports are PDF only.
- User Portal is isolated by separate session token.
- All financial/state-changing operations are atomic and idempotent.

- Mock and real APIs match the same V10 contract.
- Postman test suite covers success, validation, authorization, idempotency, and isolation scenarios.
- Prisma migration + seed + .env.example + local setup documentation are complete.

23. What Developer 2 Must NOT Invent

- Cashier or Manager roles.
- Permanent user wallet or permanent card ownership.
- Separate Kitchen entity.
- Transaction quotas/limits.
- Cross-branch Staff access.
- New permission codes without M0 update.
- Raw QR token as Staff/Admin credential.
- Organization Admin payment-gateway checkout.
- Automatic Card Session recharge webhook.
- Analytics CSV export.
- Separate analytics-download permission.
- Product Tags system.
- Different card/session lifecycle.
- Different refund logic.
- Client-controlled balance, price, organization ownership or authorization.
- Any API response envelope different from {success,data} / {success:false,error}.

24. FINAL FREEZE — V10

IMPORTANT: M0 V10 is the handover contract for Developer 2. Any deviation must be reported before implementation.

- Roles, permissions and scope are frozen.
- Database schema and relationships are frozen for V1.
- Plan transaction limits are removed.
- Organization-specific staff/branch/card overrides are frozen.
- Super Admin controls organization plan assignment and overrides.
- Org Admin uses Contact Super Admin for plan changes.
- Card Session recharge is CASH + manually verified UPI only.
- Cards support bulk CSV import and Available filtering.
- CSV import is branch-scoped and atomic.
- Products use multi-select category/attributes and no Tags.
- Analytics preview/export uses identical authorization and export is PDF only.
- Reports are PDF only.
- Demand/Peak analytics is a dedicated organization-level area.
- User Portal uses separate secure session tokens.
- Mock API mirrors the real V10 contract.
- Every endpoint in Section 7 is authoritative.
- Any future change requires explicit M0 update and review.

Appendix A — Quick Endpoint Checklist

- ☐ POST /api/v1/auth/login
- ☐ POST /api/v1/auth/refresh

- ☐ POST /api/v1/auth/logout
- ☐ GET /api/v1/auth/me
- ☐ POST /api/v1/auth/forgot-password
- ☐ POST /api/v1/auth/reset-password
- ☐ POST /api/v1/auth/change-password
- ☐ GET /api/v1/admin/organizations
- ☐ POST /api/v1/admin/organizations
- ☐ GET /api/v1/admin/organizations/:id
- ☐ PATCH /api/v1/admin/organizations/:id
- ☐ GET /api/v1/admin/plans
- ☐ POST /api/v1/admin/plans
- ☐ GET /api/v1/admin/plans/:id
- ☐ PATCH /api/v1/admin/plans/:id
- ☐ GET /api/v1/admin/organizations/:id/subscription
- ☐ PATCH /api/v1/admin/organizations/:id/subscription
- ☐ GET /api/v1/admin/organizations/:id/limit-overrides
- ☐ PATCH /api/v1/admin/organizations/:id/limit-overrides
- ☐ GET /api/v1/admin/subscriptions
- ☐ GET /api/v1/admin/subscriptions/:id
- ☐ GET /api/v1/admin/subscription-payments
- ☐ GET /api/v1/admin/plan-change-requests
- ☐ GET /api/v1/admin/plan-change-requests/:id
- ☐ PATCH /api/v1/admin/plan-change-requests/:id
- ☐ GET /api/v1/organization
- ☐ PATCH /api/v1/organization
- ☐ GET /api/v1/branches
- ☐ POST /api/v1/branches
- ☐ GET /api/v1/branches/:id
- ☐ PATCH /api/v1/branches/:id
- ☐ GET /api/v1/staff
- ☐ POST /api/v1/staff
- ☐ GET /api/v1/staff/:id
- ☐ PATCH /api/v1/staff/:id
- ☐ PUT /api/v1/staff/:id/branches
- ☐ PUT /api/v1/staff/:id/permissions
- ☐ GET /api/v1/permissions
- ☐ GET /api/v1/cards
- ☐ POST /api/v1/cards
- ☐ GET /api/v1/cards/:id
- ☐ POST /api/v1/cards/resolve
- ☐ POST /api/v1/cards/:id/block
- ☐ POST /api/v1/cards/:id/unblock
- ☐ POST /api/v1/cards/import
- ☐ GET /api/v1/cards/import/template
- ☐ POST /api/v1/card-sessions
- ☐ GET /api/v1/card-sessions
- ☐ GET /api/v1/card-sessions/:id
- ☐ POST /api/v1/card-sessions/:id/recharge
- ☐ POST /api/v1/card-sessions/:id/purchase
- ☐ POST /api/v1/card-sessions/:id/return
- ☐ POST /api/v1/card-sessions/:id/refund

- ☐ GET /api/v1/products
- ☐ POST /api/v1/products
- ☐ GET /api/v1/products/:id
- ☐ PATCH /api/v1/products/:id
- ☐ GET /api/v1/inventory
- ☐ PATCH /api/v1/inventory/:id
- ☐ POST /api/v1/inventory/import
- ☐ GET /api/v1/inventory/import/template
- ☐ GET /api/v1/analytics
- ☐ GET /api/v1/analytics/export
- ☐ GET /api/v1/reports
- ☐ GET /api/v1/reports/:id/pdf
- ☐ GET /api/v1/plans
- ☐ GET /api/v1/subscription
- ☐ GET /api/v1/subscription/payments
- ☐ GET /api/v1/subscription/payments/:id
- ☐ POST /api/v1/plan-change-requests
- ☐ GET /api/v1/plan-change-requests
- ☐ GET /api/v1/plan-change-requests/:id
- ☐ POST /api/v1/public/cards/resolve
- ☐ POST /api/v1/public/sessions/access
- ☐ GET /api/v1/public/sessions/:sessionToken
- ☐ GET /api/v1/public/sessions/:sessionToken/transactions
- ☐ GET /api/v1/public/sessions/:sessionToken/receipts

Appendix B — Developer 2 Handover Checklist

- ☐ PostgreSQL database created
- ☐ Prisma schema matches V10
- ☐ Prisma migration created and tested
- ☐ Seed script created
- ☐ .env.example created
- ☐ Authentication module complete
- ☐ Authorization middleware complete
- ☐ Organization/branch isolation tested
- ☐ Staff permissions tested
- ☐ Card lifecycle tested
- ☐ Card CSV import tested
- ☐ Main Cafeteria CSV import tested
- ☐ Card Session monitoring endpoint tested
- ☐ Recharge tested for CASH and verified UPI
- ☐ Purchase concurrency/idempotency tested
- ☐ Refund/return tested
- ☐ Product multi-category tested
- ☐ Tags removed from DB/API
- ☐ Inventory CSV atomicity tested
- ☐ Analytics + branch comparison tested
- ☐ Analytics PDF export tested
- ☐ Reports PDF tested
- ☐ Plan assignment tested

- ☐ Organization-specific overrides tested
- ☐ Plan Change Request flow tested
- ☐ User Portal isolation tested
- ☐ Audit logs tested
- ☐ Mock API contract parity tested
- ☐ Postman collection/tests completed
- ☐ API documentation generated/updated
- ☐ No V9 removed endpoints remain exposed